Lesson 9

Implementing Secure Network Designs

CompTIA®

Topic 9A

Implement Secure Network Designs

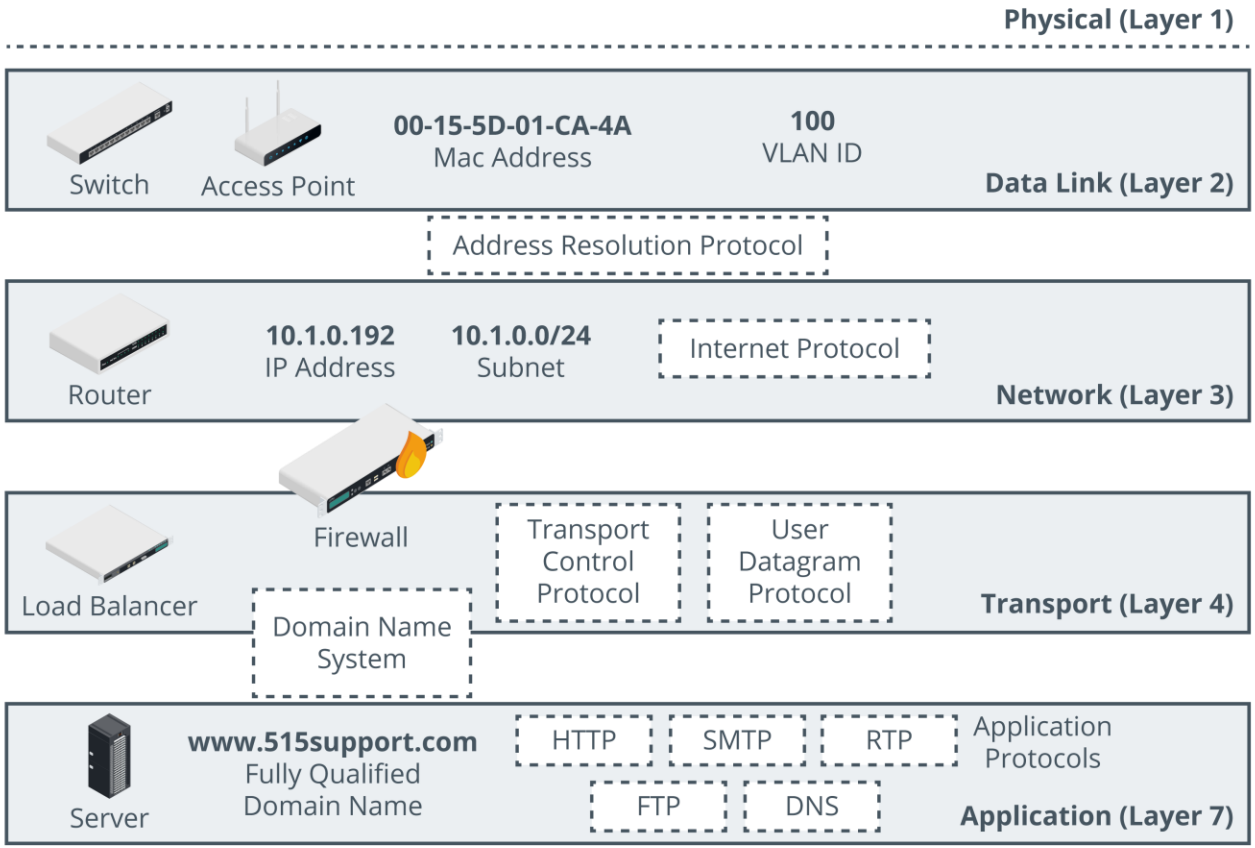
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Secure Network Designs

- What problems arise from weaknesses in the network design/architecture?
  - Single points of failure
  - Complex dependencies
  - Availability over confidentiality and integrity
  - Lack of documentation and change control
  - Overdependence on perimeter security
- Best practice design and architecture guides
  - Cisco's SAFE Architecture
  - Places in the Network

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Network Appliances



Images © 123rf.com.

Routing and Switching Protocols

- Forwarding
  - Layer 2 forwarding
  - Layer 3 forwarding
- Address Resolution Protocol (ARP)
  - Map IP addresses to MAC addresses
- Internet Protocol (IP)
  - IPv4 and IPv6
  - Network prefix/subnet mask
- Routing protocols
  - Communicate routing table updates

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

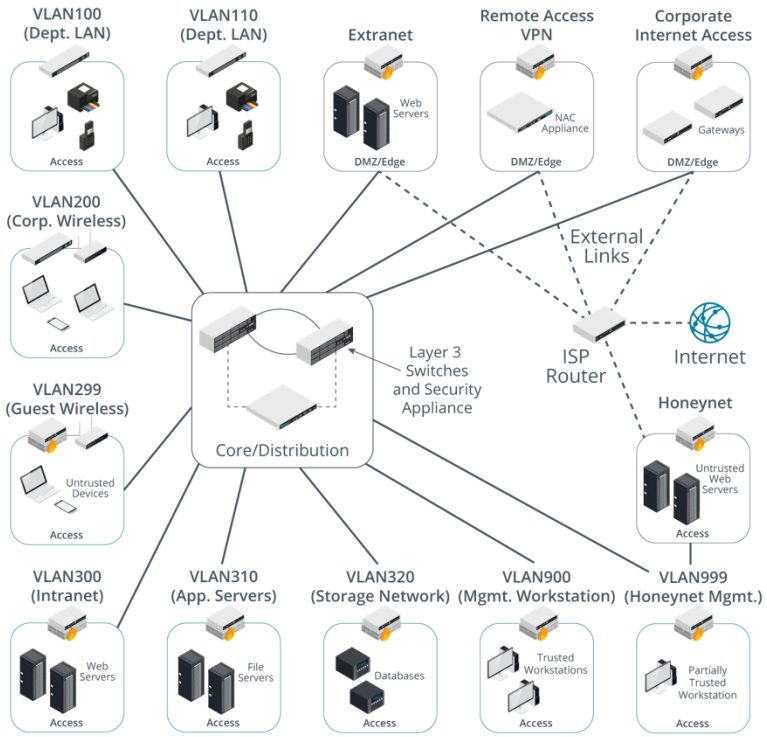
Network Segmentation

- Network segment
  - Nodes can communicate at layer 2
  - Broadcast domain
- Implementing network segments
  - Separate unmanaged switches
  - Configure virtual LANs (VLANs) on managed switches
- Layer 3 subnets
  - Map subnets to VLANs

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

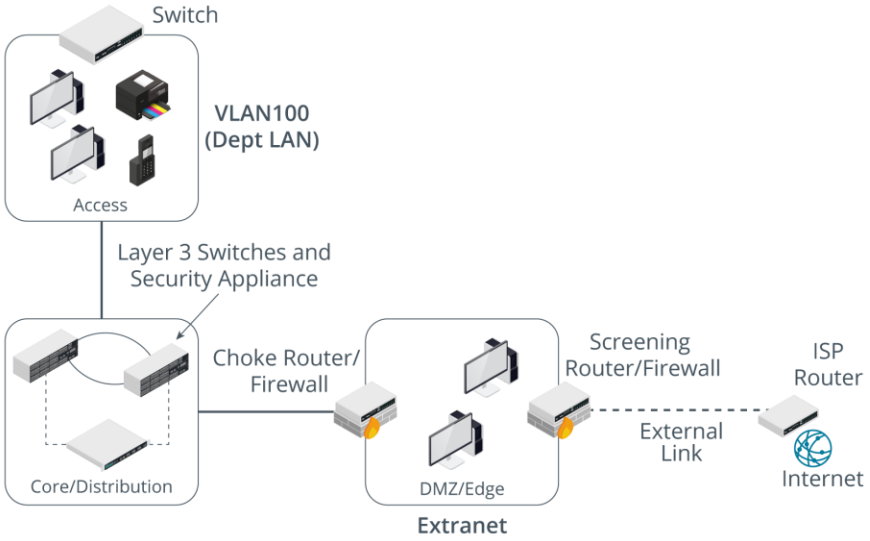
Network Topology and Zones

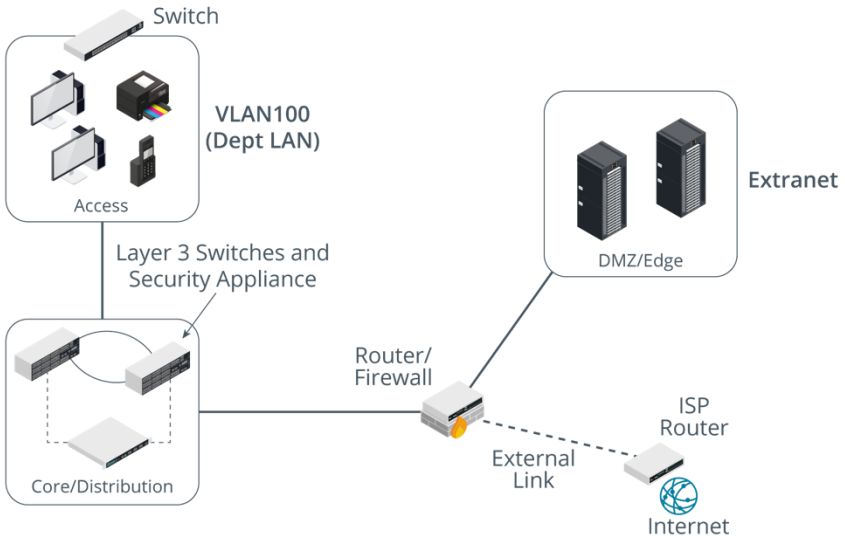
- Physical and logical topologies
- Zones represent isolated segments for hosts that have the same security requirement
- Traffic between zones is subject to filtering by a firewall
- Main zone types
  - Intranet (private)
  - Extranet
  - Internet (public)
- Enterprise architecture zones
  - Access blocks representing host groups



Images © 123rf.com.

Demilitarized Zone Topologies





Images © 123rf.com.

Implications of IPv6

- Enabled by default configuration issues
  - Risks of unmanaged configurations
  - IPv6-specific attack vectors
- Map IPv6 address space to appropriate security zones
- Configure IPv6 firewall rules
- Typically no need for address translation

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Other Secure Network Design Considerations

- Data center and cloud design requirements
- East-west traffic
  - North-south traffic enters and leaves data center
  - East-west traffic is between servers within the data center
  - Problem for security inspection and filtering
- Zero trust
  - Do not rely on perimeter security
  - Continuous/context-based authentication
  - Microsegmentation
    - Single host zones

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 9B

Implement Secure Switching and Routing

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

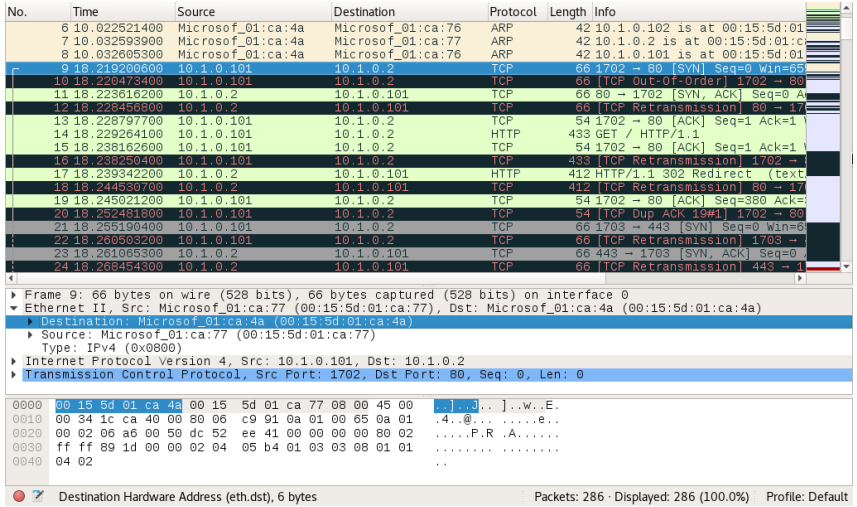
Man-in-the-Middle and Layer 2 Attacks

- Man-in-the-Middle (MitM) attacks
  - Threat actor can intercept and modify communications
  - On-path attack
  - Snooping
  - Spoofing
- MAC address cloning/spoofing
  - Media Access Control (MAC) hardware interface address
  - Easy to change for a different value

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

ARP Poisoning and MAC Flooding Attacks

- Address Resolution Protocol (ARP) poisoning
  - Broadcasting unsolicited ARP replies to poison the cache of local hosts with spoofed MAC address
  - Attacker usually tries to masquerade as default gateway
- MAC flooding
  - Overwhelm switch memory to trigger unicast flooding
  - Facilitates sniffing



Screenshot used with permission from wireshark.org.

Physical Port Security and MAC Filtering

- Physical port security
  - Secure switch hardware
  - Physically disconnect unused ports
  - Disable unused ports via management interface
- MAC address limiting and filtering
  - Configure permitted MACs
  - Limit number of MAC changes
- DHCP snooping
  - Dynamic ARP inspection

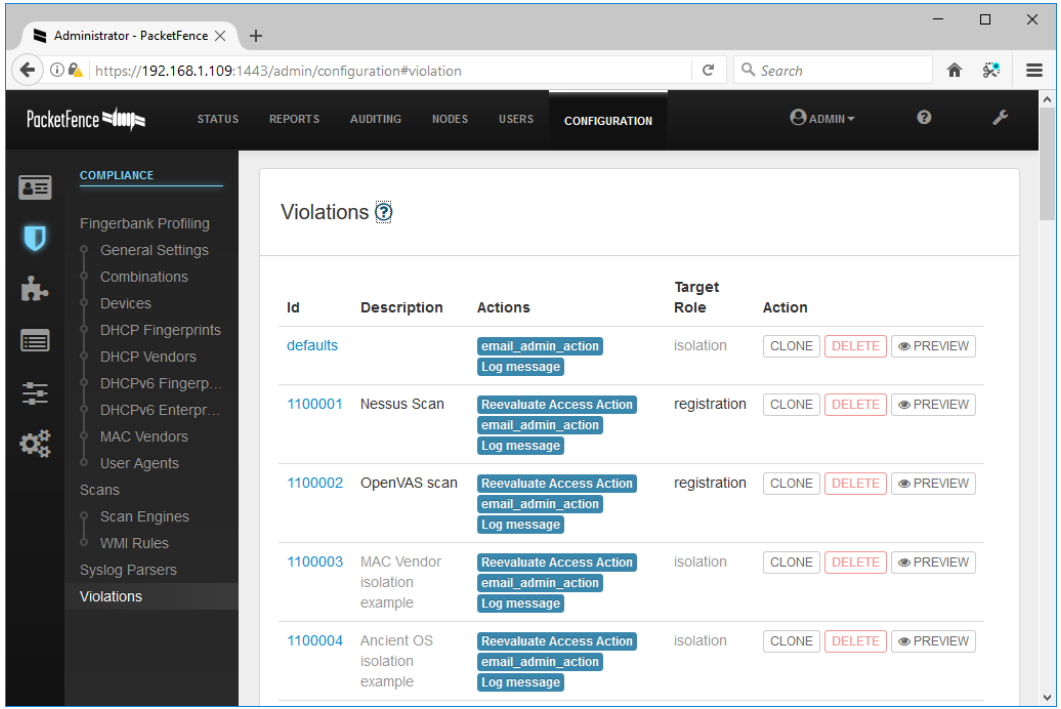
```
NYCORE1>
NYCORE1#
*Mar  1 00:02:27.991: %SYS-5-CONFIG_I: Configured from console by console
*Mar  1 00:02:46.287: %LINEPROTO-5-UPDOWN: Line protocol on Interface Vlan1, changed state to up
NYCORE1#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
NYCORE1(config)#ip arp inspection vlan 1,999
NYCORE1(config)#
*Mar  1 00:07:20.561: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Req) on Fa1/0/23, vlan 1.([0023.04
0.0000/192.168.16.21/00:07:20 UTC Mon Mar 1 1993])
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Network Access Control

- Endpoint security/defense in depth
- IEEE 802.1X/port-based network access control (PNAC)
- Can also enforce health policy
- Posture assessment
  - Agent-based
    - Persistent versus non-persistent
  - Agentless
    - Scanning software
    - Device polling

Screenshot used with permission from packetfence.org.



Route Security

- Sources of routing table updates
- Preventing route injection
- Source routing
- Patch management and router appliance hardening

```
vyos@RT3-INT:~$ show ip route
Codes: K - kernel route, C - connected, S - static, R - RIP, O - OSPF,
       I - ISIS, B - BGP, > - selected route, * - FIB route

S>* 0.0.0.0/0 [1/0] via 192.168.1.253, eth1
B>* 10.1.0.0/24 [20/0] via 172.16.1.253, eth0, 00:10:25
C>* 127.0.0.0/8 is directly connected, lo
B>* 172.16.0.252/30 [20/1] via 172.16.1.253, eth0, 00:10:25
C>* 172.16.1.252/30 is directly connected, eth0
C>* 192.168.1.0/24 is directly connected, eth1
C>* 192.168.2.0/24 is directly connected, eth2
vyos@RT3-INT:~$
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Lesson 9C

Implement Secure Wireless Infrastructure

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

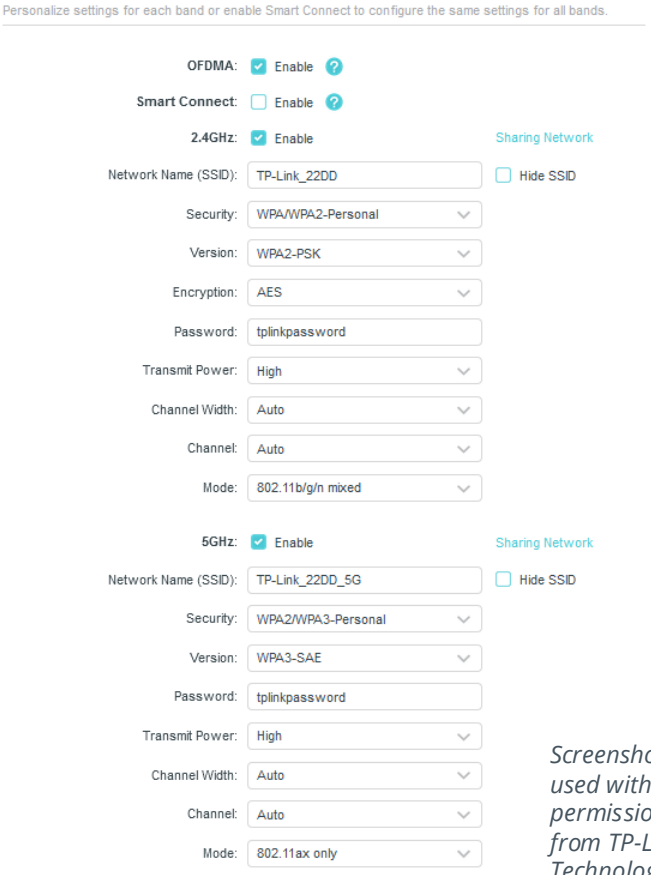
Wireless Network Installation Considerations

- Ensure maximum availability from legitimate access points
- Wireless access point (WAP) placement
  - Service set identifier (SSID) and basic service set identifier (BSSID)
  - Frequency bands and channels
  - Co-channel interference (CCI)
  - Adjacent channel interference (ACI)
- Site surveys and heat maps
  - Architectural plan
  - Wi-Fi analyzer
  - Heat map plots signal strength from high (red) to low (green/blue)
  - Channel layout shows overlapping usage

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Wi-Fi Protected Access

- WPA (v1)
  - RC4 with Temporal Key Integrity Protocol (TKIP)
- Wi-Fi protected access 2 (WPA2)
  - Advanced Encryption Standard (AES) replaces RC4
  - Counter Mode with Cipher Block Chaining Message Authentication Code (CBC-MAC) Protocol (CCMP) replaces TKIP
  - Also enables enterprise authentication options
- Wi-Fi protected access 3 (WPA3)
  - Simultaneous Authentication of Equals (SAE)
  - Enhanced Open
  - Updated cryptography
  - Management protection frames



Screenshot used with permission from TP-Link Technologies.

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Wi-Fi Authentication Methods

- WPA2 pre-shared key authentication
  - Passphrase used to generate a pairwise master key (PMK)
  - 4-way handshake
  - PMK is used to derive session keys
- WPA3 personal authentication
  - Password Authenticated Key Exchange (PAKE)
  - Simultaneous Authentication of Equals (SAE) protocol replaces the 4-way handshake
  - Dragonfly handshake

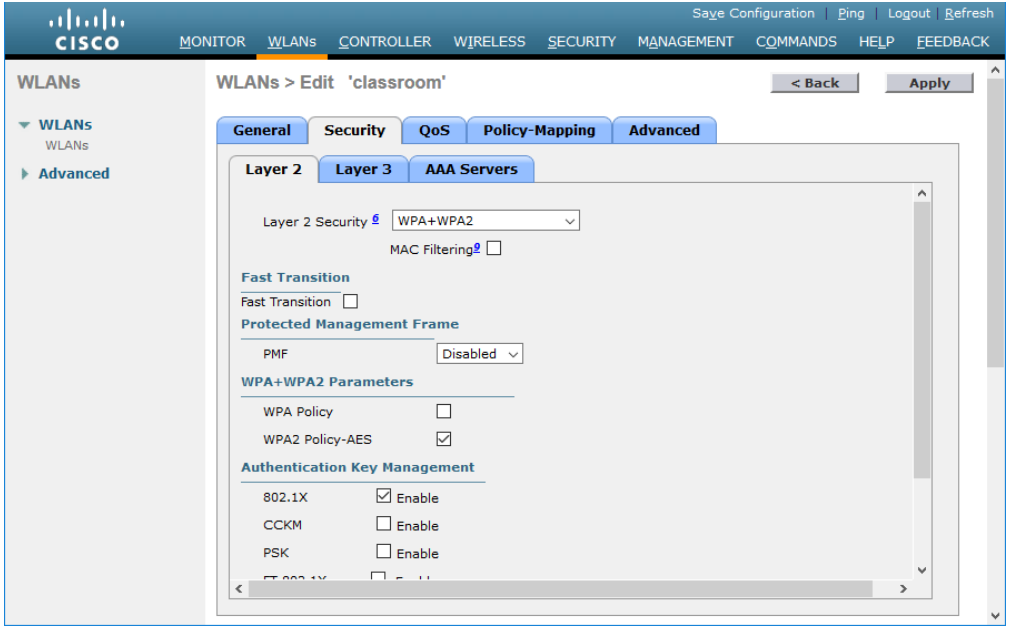
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Wi-Fi Protected Setup (WPS)

- Pushbutton or passcode autoconfiguration of access points and clients
- Brute-force vulnerability in passcode algorithm
- Access point may support lockout to mitigate
- Make sure access point firmware is up-to-date
- EasyConnect and Device Provisioning Protocol (DPP)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Enterprise/IEEE 802.1X Authentication

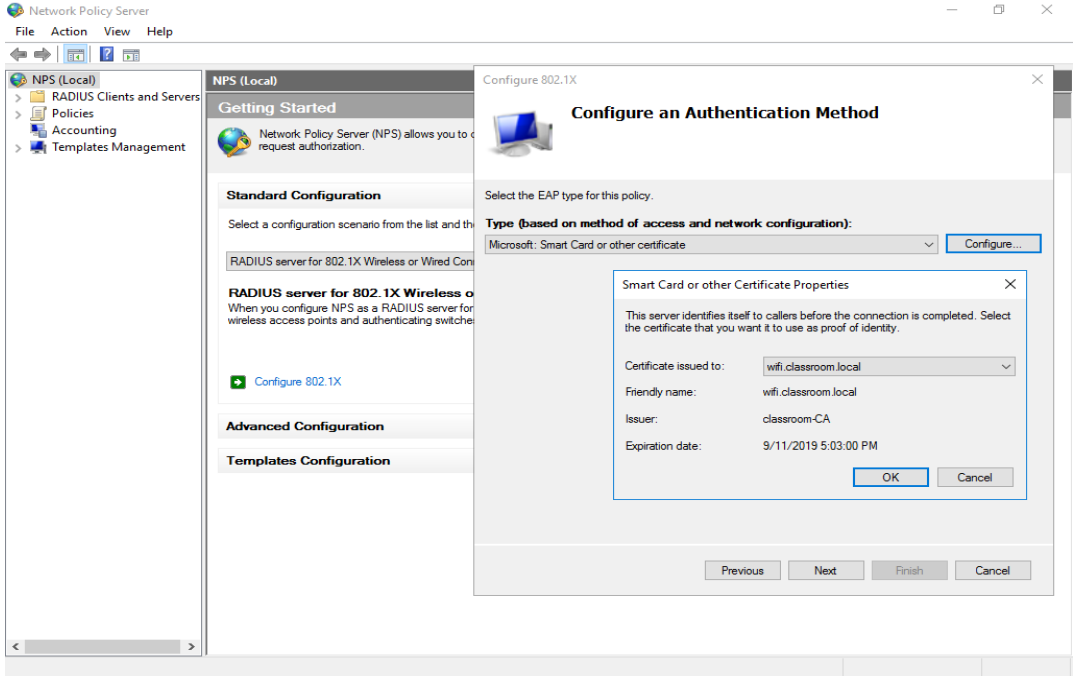


Screenshot used with permission from Cisco.

- Extensible Authentication Protocol (EAP) over Wireless (EAPoW)
- Network directory authorization via RADIUS or TACACS+
- User credential is used to generate session encryption key

Extensible Authentication Protocol

- Designed to provide for interoperable security devices and software
- EAP-TLS
  - Transport Layer Security (TLS) to authenticate via device certificates/smart cards
  - Both server and supplicant must have certificates
  - Mutual authentication



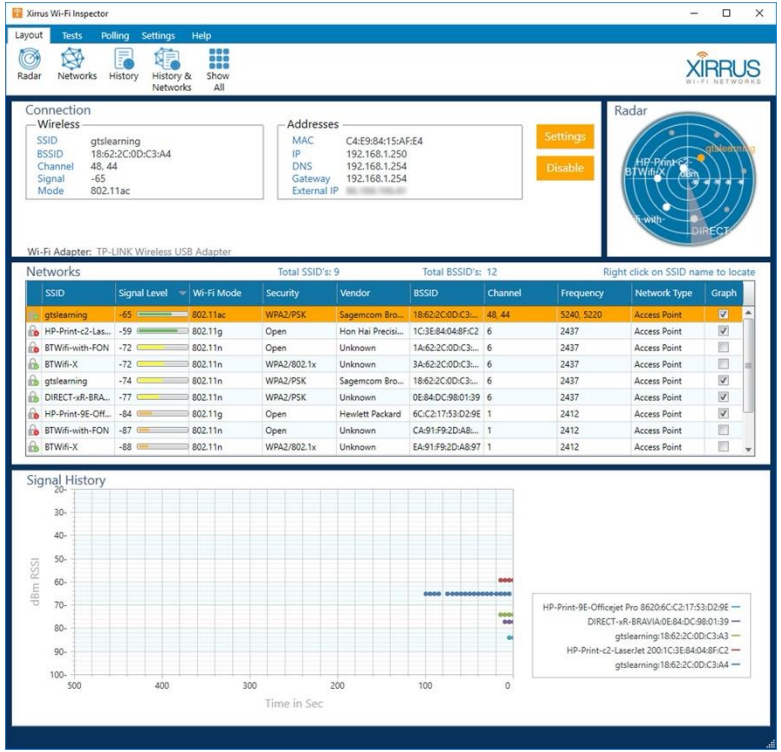
Screenshot used with permission from Microsoft.

PEAP, EAP-TTLS, and EAP-FAST

- Secure tunneling for user credentials
- Protected EAP (PEAP)
  - Password authentication through a TLS-protected tunnel
  - Server certificate only
  - PEAPv0 (EAP-MSCHAPv2)
  - PEAPv1 (EAP-GTC)
- EAP with Tunneled TLS (EAP-TTLS)
  - Similar to PEAP but with more flexibility on inner authentication method
- EAP with Flexible Authentication via Secure Tunneling (EAP-FAST)
  - Cisco alternative to PEAP that can be set up without certificate infrastructure

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Rogue Access Points and Evil Twins



Screenshot used with permission from Xirrus.

- Rogue access point
  - Troubleshooting access point misconfiguration
  - Disable unused devices and interfaces
- Evil twin
  - Masquerade as legitimate AP
  - Use similar SSID
  - Capture authentication information
- Wi-Fi analyzers

Jamming Attacks

- Environmental versus malicious interference
- Jamming attacks
  - Denial of service
  - Promote evil twin
- Use spectrum analyzer to locate source

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 9D

Implement Load Balancers

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Distributed Denial of Service (DDoS)

- Leverage bandwidth from compromised hosts/networks
  - Handlers form a command and control (C&C) network
  - Compromised hosts installed with bots that can run automated scripts
  - Co-ordinated by the C&C network as a botnet
- Overwhelm with superior bandwidth (number of bots)
- Consume resources with spoof session requests (SYN flood)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

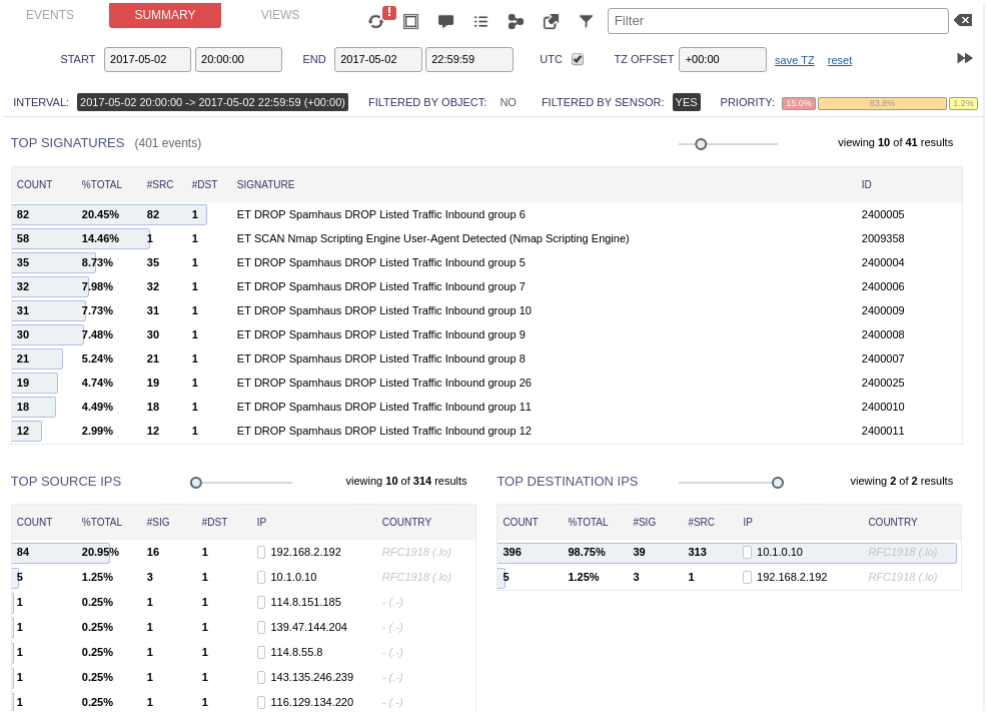
Amplification, Application, and OT Attacks

- Distributed Reflection DoS (DRDoS)
- Amplified SYN flood
  - Spoof victim's IP address and attempt to open connections with multiple servers
  - Those servers direct their SYN/ACK responses to the victim
- Application attacks
  - Bogus DNS/NTP queries
  - Direct responses at victim
  - Queries can be constructed to generate large response packets
- Operational technology (OT) networks
  - DoS against embedded systems
  - Can be more vulnerable to miscrafted packets than computing hosts

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

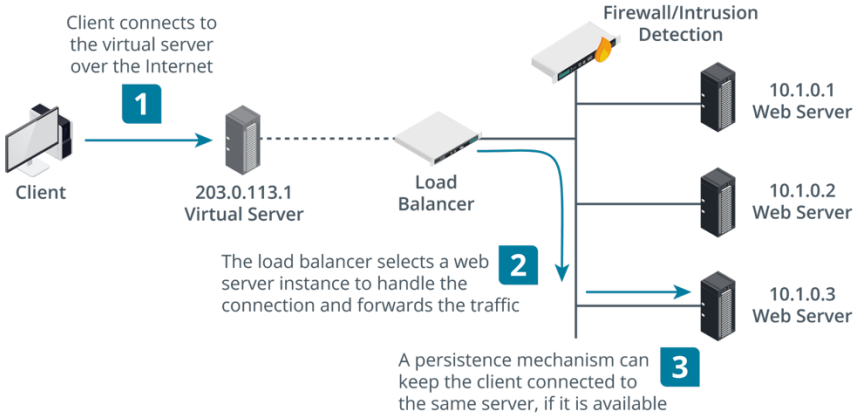
Distributed Denial of Service Attack Mitigation

- Attacks use spoofed addresses, making them hard to block
- Drop traffic to protect other hosts in the routing domain
  - Access control list (ACL)
  - remotely triggered blackhole (RTBH)
  - Sinkhole routing
- Cloud DDoS mitigation services



Screenshot used with permission from Security Onion.

Load Balancing

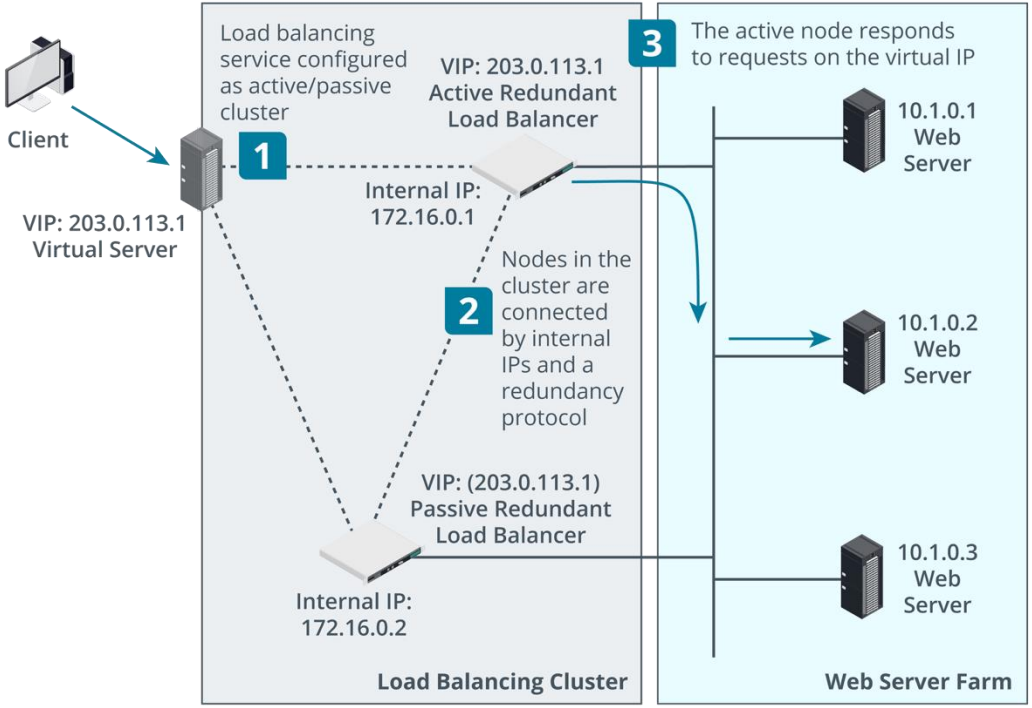


Images © 123rf.com.

- Distributes requests across farm or pool of servers (nodes)
  - Layer 4 load balancer
  - Layer 7 load balancer (content switch)
- Scheduling
  - Round robin
  - Fewest existing connections / best response time
  - Weighting
  - Heartbeat and health checks
- Source IP affinity
- Session persistence

Clustering

- Configure nodes for failover
- Virtual IP
  - Common Address Redundancy Protocol (CARP)
- Active/passive versus active/active
- Application clustering
  - Provides stateful fault tolerance



Images © 123RF.com.

Quality of Service

- Compared to best effort and first in, first out (FIFO)
- Quality of service (QoS) to prioritize traffic with certain characteristics
  - Bandwidth
  - Latency and jitter
- Traffic marking
  - DiffServ and 802.1p
- Traffic policing
- Denial of service and trust boundaries for traffic marking
  - Ensure bandwidth for management and security monitoring traffic

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 10A

Implement Firewalls and Proxy Servers

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

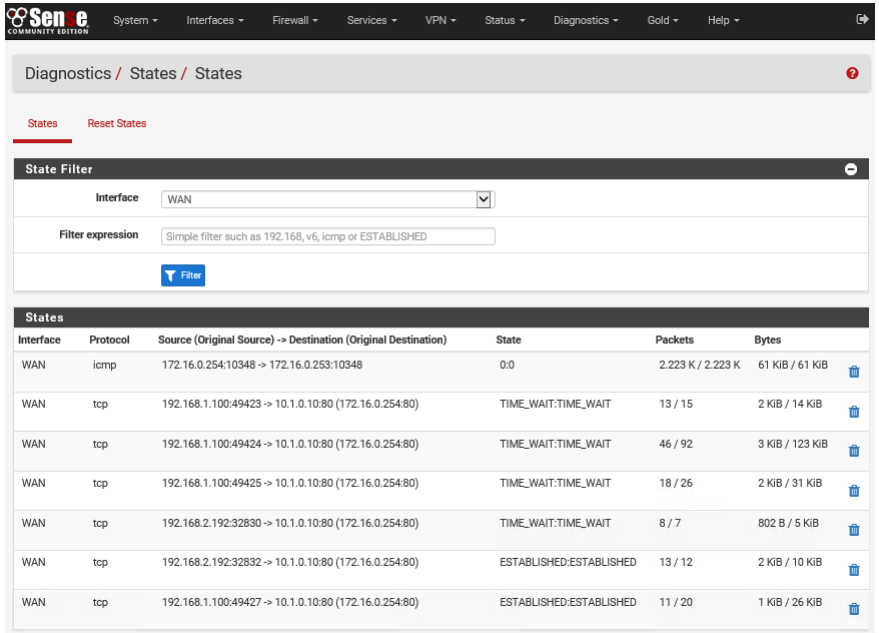
Packet Filtering Firewalls

- Enforce a network access control list (ACL)
- Act to deny (block or drop), log, or accept a packet
- Inspect headers of individual packets
  - Source and destination IP address
  - Protocol ID/type (TCP, UDP, ICMP, routing protocols, and so on)
  - Source and destination port numbers (TCP or UDP application type)
- Inbound, outbound, or both
- Stateless operation

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Stateful Inspection Firewalls

- State table stores connection information
- Transport layer (layer 4)
  - TCP handshake
  - New versus established and related connections
- Application layer (layer 7)
  - Validate protocol
  - Match threat signatures
  - Application-specific filtering



Screenshot used with permission from Rubicon Communications, LLC

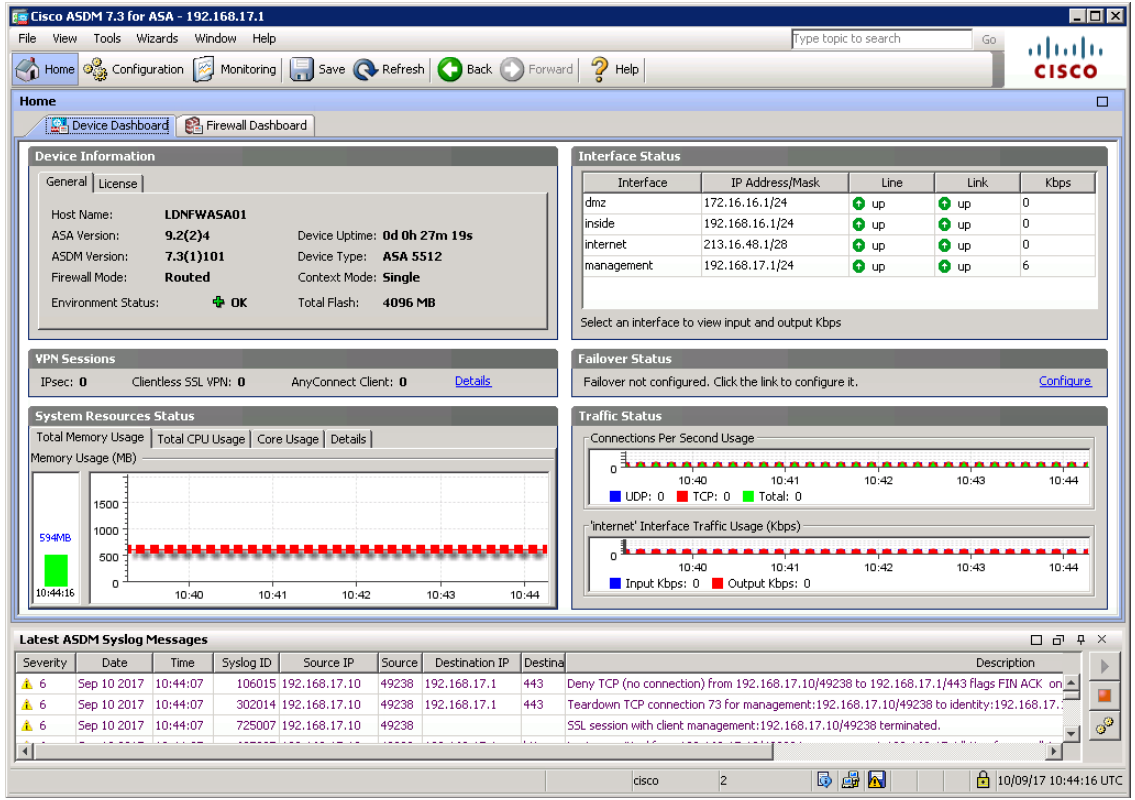
iptables

```
Chain INPUT (policy DROP)
num  target    prot  opt  source          destination
1    DROP      all   --   10.1.0.192      0.0.0.0/0
2    ACCEPT    icmp  --   10.1.0.0/24     0.0.0.0/0      icmptype 8
3    ACCEPT    udp   --   0.0.0.0/0       0.0.0.0/0      udp dpt:53
4    ACCEPT    tcp   --   0.0.0.0/0       0.0.0.0/0      tcp dpt:53
5    ACCEPT    tcp   --   10.1.0.0/24     0.0.0.0/0      tcp dpt:80
6    ACCEPT    tcp   --   10.1.0.0/24     0.0.0.0/0      tcp dpt:443
7    ACCEPT    all   --   0.0.0.0/0       0.0.0.0/0      ctstate RELATED,ESTABLISHED
[i@host]$ iptables -I INPUT 2 -p tcp -s 10.1.0.0/24 --dport 22 -j ACCEPT
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Firewall Implementation

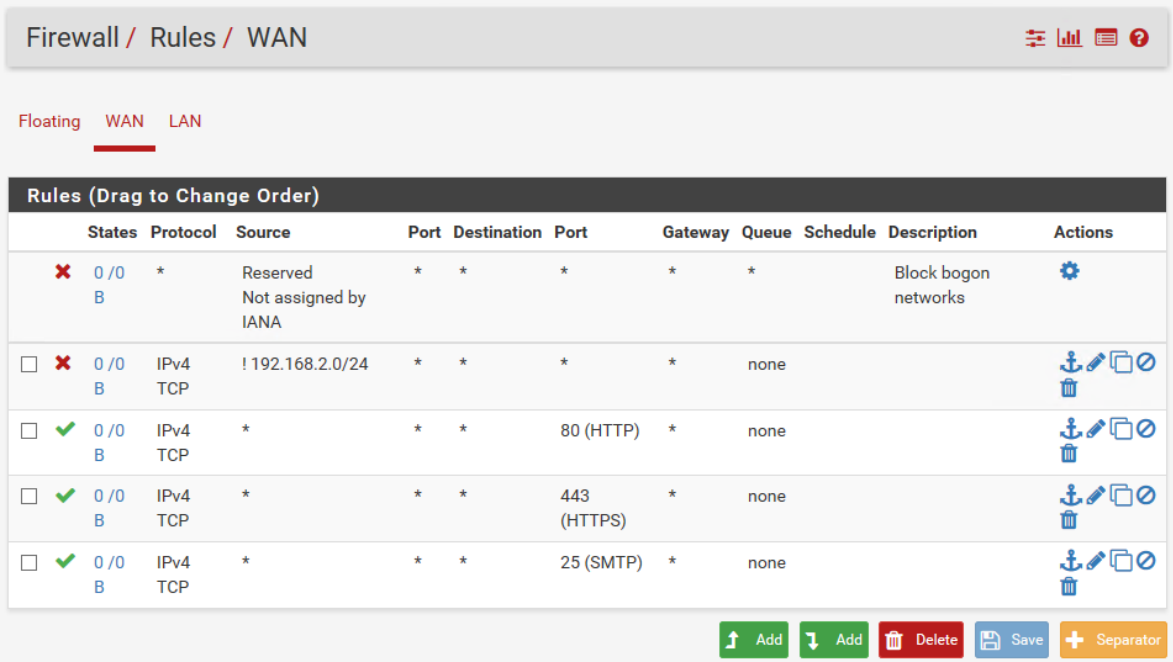
- Firewall appliances
  - Routed (layer 3)
  - Bridged/transparent (layer 2)
  - Router/firewall
- Application-based firewalls
  - Host-based (personal)
  - Application firewall
  - Network operating system (NOS) firewall



Screenshot used with permission from Cisco.

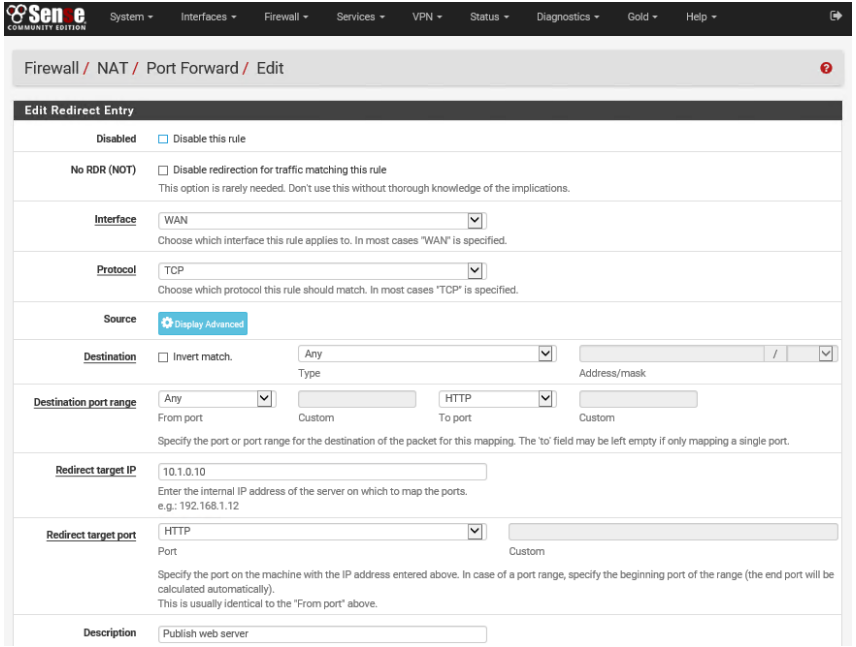
Access Control Lists

- Least access
- Top to bottom processing order
- Implicit deny
- Explicit deny all
- Criteria for rules (tuples)
- Documenting and testing configuration



Screenshot used with permission from Rubicon Communications, LLC.

Network Address Translation



Screenshot used with permission from Rubicon Communications, LLC.

- Source NAT
  - Static and dynamic NAT
  - Overloaded NAT/Network Address Port Translation (NAPT)/Port Address Translation (PAT)
- Destination NAT/port forwarding
  - Advertise a resource using a global IP address but forward it to a local IP address
  - Usually forward specific ports only

Virtual Firewalls

- Hypervisor-based
  - Filtering built into the hypervisor or cloud service
- Virtual appliance
  - Deployed as a virtual machine to the cloud
- Multiple context
  - Firewall appliance running multiple instances
- East-west security design and microsegmentation

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Open-source versus Proprietary Firewalls

- Source code inspection and supply chain issues
  - Wholly proprietary appliance OS
  - UNIX or Linux kernel with proprietary features
  - Wholly open-source
- Support arrangements and subscription features

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

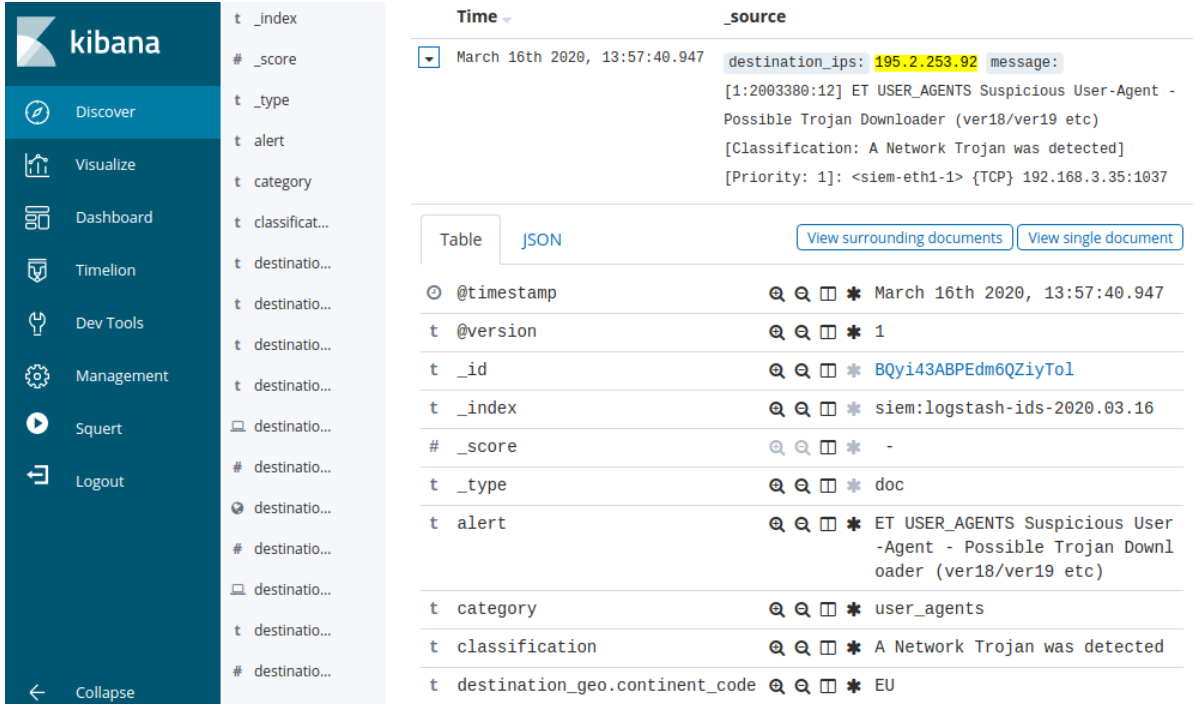
Topic 10B

Implement Network Security Monitoring

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Network-Based Intrusion Detection Systems

- Intrusion detection system (IDS)
- Network sensor captures traffic
- Detection engine performs real-time analysis of indicators
- Passive logging/alerting



Screenshot Security Onion securityonion.net

Network-Based Intrusion Prevention Systems

- Intrusion prevention system (IPS)
- Active response to threats
  - Reset session
  - Apply firewall filters on the fly to shun traffic
  - Bandwidth throttling
  - Packet modification
  - Run a script or other process
- Anti-virus scanning/content filtering
- Inline placement—risk of failure

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Signature-Based Detection

```
  GNU nano 2.5.3                    File: downloaded.rules

# ----- Begin ET-emerging-activex Rules Category ----- #

# -- Begin GID:1 Based Rules -- #

#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Internet Explorer Plugin.ocx Heap Overfl$
alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX winhlp32 ActiveX control attack - phase 1$
alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX winhlp32 ActiveX control attack - phase 2$
alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX winhlp32 ActiveX control attack - phase 3$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX MciWndx ActiveX Control"; flow:from_serv$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX COM Object Instantiation Memory Corrupti$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Danim.dll and Dxtmsft.dll COM Objects"; $
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX JuniperSetup Control Buffer Overflow"; f$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Wmm2fxa.dll COM Object Instantiation Mem$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Multimedia Controls - ActiveX $
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Multimedia Controls - ActiveX $
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Multimedia Controls - ActiveX $
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft WMIScriptUtils.WMIObjectBroker$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft VsmIDE.DTE object call CSLID";$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft DExplore.AppObj.8.0 object cal$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft VisualStudio.DTE.8.0 object ca$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Microsoft.DbgClr.DTE.8.0 objec$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft VsaIDE.DTE object call CSLID";$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Business Object Factory object$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Outlook Data Object object cal$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Microsoft Outlook.Application object cal$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX ACTIVEX Possible Microsoft IE Install En$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Possible Microsoft IE Install Engine Ins$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Possible Microsoft IE Shell.Application $
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX ACTIVEX Possible Microsoft IE Shell.Appl$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX NCTAudioFile2 ActiveX SetFormatLikeSampl$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Possible Microsoft Internet Explorer ADO$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Sony ImageStation (SonyISUpload.cab 1.0.$
#alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET ACTIVEX Citrix Presentation Server Client WFICA.$
                              [ Read 27185 lines (Warning: No write permission) ]
```

- Analysis engine
- Signature-based detection
  - Pattern matching
  - Database of known attack signatures
  - Must be updated with latest definitions /plug-ins/feeds
  - Many attack tools do not conform to specific signatures

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Behavior and Anomaly-Based Detection

- Behavioral-based detection
  - Train sensor with baseline normal behavior to recognize anomalous behavior
  - Network behavior and anomaly detection (NBAD)
  - Heuristics (learning from experience)
  - Statistical model of behavior
  - Machine learning assisted analysis
    - User and entity behavior analytics (UEBA)
    - Network traffic analysis (NTA)
- Anomaly-based detection as irregularity in packet construction

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

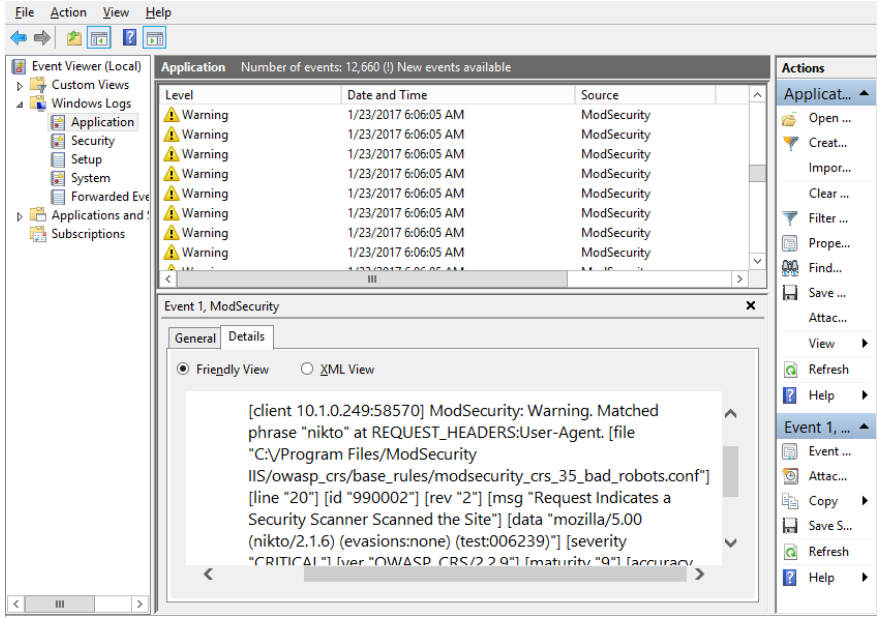
Host-Based Intrusion Detection Systems

- Host-based IDS
  - Network, log, and file system monitoring for endpoints
- File integrity monitoring (FIM)
  - Cryptographic hash or file signature verifies integrity of files
  - Compare hashes manually or verify signature with publisher's public key
  - Windows File Protection/`sfc`
  - Tripwire and OSSEC

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Web Application Firewalls

- Able to inspect code in HTTP packets
- Matches suspicious code to vulnerability database
- Can be implemented as software on host or as appliance



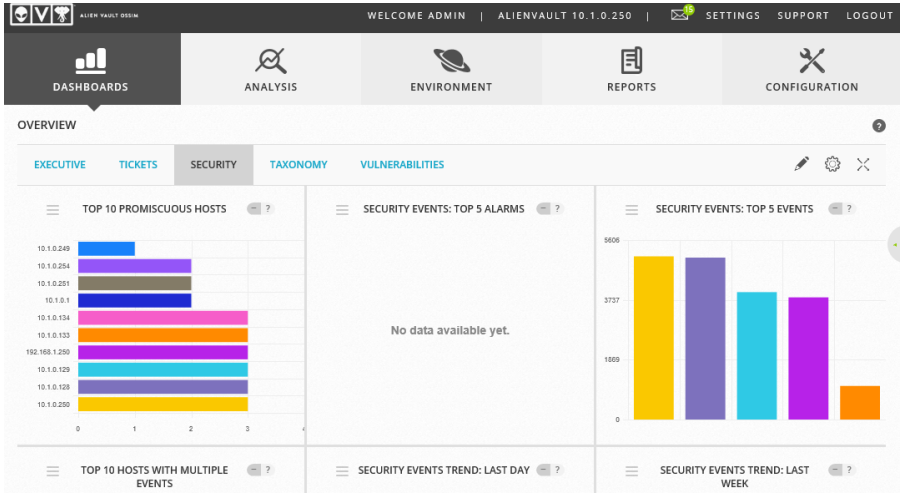
Screenshot used with permission from Microsoft.

Topic 10C

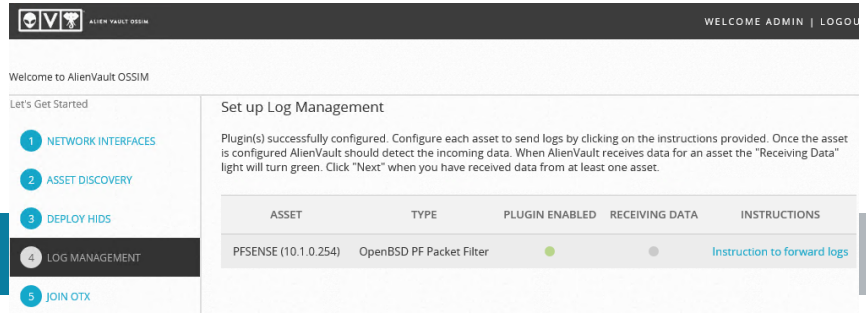
Summarize the Use of SIEM

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Security Information and Event Management



- Log collection
  - Agent-based
    - Local agent to forward logs
  - Listener/collector
    - Protocol-based remote log forwarding (syslog)
  - Sensor
    - Packet capture and traffic flow data
- Log aggregation
  - Consolidation of multiple log formats to facilitate search/query and correlation
  - Normalization of fields
  - Time sy



Screenshots used with permission from AT&T Cybersecurity.

Analysis and Report Review

- Correlation
  - Relating security data and threat intelligence
  - Alerting of indicators of compromise (IOC)
  - Basic rules versus machine learning
- User and entity behavior analytics (UEBA)
- Sentiment analysis
  - Machine interpretation of natural language
  - Emotion AI
- Security orchestration, automation, response (SOAR)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 11A

Implement Secure Network Operations Protocols

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Network Address Allocation

```
msf auxiliary(dhcp) > set dhcpipend 10.1.0.210
dhcpipend => 10.1.0.210
msf auxiliary(dhcp) > set netmask 255.255.255.0
netmask => 255.255.255.0
msf auxiliary(dhcp) > set dnsserver 10.1.0.192
dnsserver => 10.1.0.192
msf auxiliary(dhcp) > set router 10.1.0.192
router => 10.1.0.192
msf auxiliary(dhcp) > set srvhost 10.1.0.192
srvhost => 10.1.0.192
msf auxiliary(dhcp) > show options

Module options (auxiliary/server/dhcp):

   Name          Current Setting  Required  Description
   ----          ---------------  --------  -----------
   BROADCAST                      no        The broadcast address to send to
   DHCPIPEND     10.1.0.210       no        The last IP to give out
   DHCPIPSTART   10.1.0.200       no        The first IP to give out
   DNSSERVER     10.1.0.192       no        The DNS server IP address
   DOMAINNAME                     no        The optional domain name to assign
   FILENAME                       no        The optional filename of a tftp boot
server
   HOSTNAME                       no        The optional hostname to assign
   HOSTSTART                      no        The optional host integer counter
   NETMASK       255.255.255.0    yes       The netmask of the local subnet
   ROUTER        10.1.0.192       no        The router IP address
   SRVHOST       10.1.0.192       yes       The IP of the DHCP server


Auxiliary action:

   Name     Description
   ----     -----------
   Service


msf auxiliary(dhcp) > run
[*] Auxiliary module execution completed

[*] Starting DHCP server...
msf auxiliary(dhcp) >
```

```
root@KALI:~# dnsspoof -i eth0 -f /root/pharm.txt
dnsspoof: listening on eth0 [udp dst port 53 and not src 10.1.0.192]
```

```
[--->] DHCP_Discover
[--->] DHCP_Discover
[--->] DHCP_Discover
[--->] DHCP_Discover
[ -- ] timeout waiting on dhcp packet count 3
[--->] DHCP_Discover
[--->] DHCP_Discover
[ ?? ]                    waiting for DHCP pool exhaustion...
[--->] DHCP_Discover
[--->] DHCP_Discover
[--->] DHCP_Discover
[--->] DHCP_Discover
[--->] DHCP_Discover
[ -- ] timeout waiting on dhcp packet count 4
[ ?? ]                    waiting for DHCP pool exhaustion...
[ -- ] [DONE] DHCP pool exhausted!

root@KALI:~#
```

- Dynamic versus static IP address assignment
- Dynamic Host Configuration Protocol (DHCP)
- Prevent rogue DHCP servers
- Prevent DoS attacks (starvation) by rogue clients
- Secure administration interface

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Domain Name Resolution

- System for resolving host names and domain labels to IP addresses
- Domain hijacking
  - Gain control of domain registration
  - whois
- Uniform Resource Locator (URL) redirection
  - Abuse of HTTP redirects and .htaccess redirects
- Domain reputation
  - Monitor blocklists/reputation lists for abuse of your domain

```
https://trusted.foo/login.php
?url="https://tru5ted.foo"
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

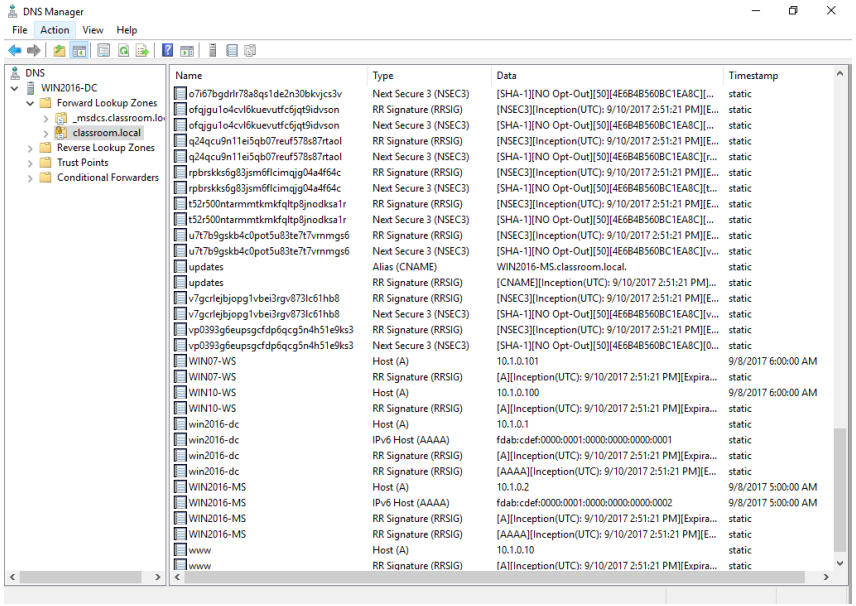
DNS Poisoning

- Man in the Middle
  - Rogue DNS server intercepts queries
- DNS client cache poisoning
  - HOSTS file
- DNS server cache poisoning
  - Corrupt cached records on DNS servers
  - Spoof responses to queries by exploiting weak transaction ID generation
  - DNS authoritative name server impersonation

```
   HOSTNAME   www.web.local    yes       Hostname to hijack
   INTERFACE                   no        The name of the interface
   NEWADDR    192.168.2.192    yes       New address for hostname
   RECONS     192.168.2.254    yes       The nameserver used for reconnaissance
   RHOST      192.168.1.1      yes       The target address
   SNAPLEN    65535            yes       The number of bytes to capture
   SRCADDR    Real             yes       The source address to use for sending t
he queries (Accepted: Real, Random)
   SRCPORT    0                yes       The target server's source query port (
0 for automatic)
   TIMEOUT    500              yes       The number of seconds to wait for new d
ata
   TTL        46348            yes       The TTL for the malicious host entry
   XIDS       0                yes       The number of XIDs to try for each quer
y (0 for automatic)

msf auxiliary(bailiwicked_host) > run

[-] Failure: This hostname is already in the target cache: www.web.local
[-]          Cache entry expires on 2017-09-17 09:08:17 -0700... sleeping.
^C[-] Auxiliary interrupted by the console user
[*] Auxiliary module execution completed
msf auxiliary(bailiwicked_host) > set hostname updates.web.local
hostname => updates.web.local
msf auxiliary(bailiwicked_host) > run

[*] Targeting nameserver 192.168.1.1 for injection of updates.web.local. as 192.
168.2.192
[*] Querying recon nameserver for web.local.'s nameservers...
[*]  Got an NS record: web.local.              604800  IN      NS      ns.web.lo
cal.
[*]   Querying recon nameserver for address of ns.web.local....
[*]    Got an A record: ns.web.local.           604800  IN      A       192.168.
1.1
[*]     Checking Authoritativeness: Querying 192.168.1.1 for web.local....
[*]     ns.web.local. is authoritative for web.local., adding to list of nameser
vers to spoof as
[*] Calculating the number of spoofed replies to send per query...
[*]   race calc: 100 queries | min/max/avg time: 0.0/0.0/0.0 | min/max/avg repli
es: 0/1/0
[*] The server did not reply, giving up.
[*] Auxiliary module execution completed
msf auxiliary(bailiwicked_host) >
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

DNS Security



Screenshot used with permission from Microsoft.

- DNS server security
  - Fault tolerance
  - Authenticated recursive requests only
  - Access control
  - Patch management
  - Prevent footprinting
- DNS Security Extensions (DNSSEC)
  - RRset
  - Zone Signing Key
  - Key Signing Key
  - Root of Trust

Topic 11B

Implement Secure Application Protocols

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

HyperText Transport Protocol and Web Services

- HTTP headers and payload
- Web services/applications
  - Forms mechanism allows client to upload data to the server
  - Stateless protocol but expanded with cookies and scripting

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Transport Layer Security

- Secure Sockets Layer (SSL)/Transport Layer Security (TLS)
  - Communications secured using host certificates
- SSL/TLS versions
- Cipher suites
  - Key exchange – authentication – confidentiality - HMAC
    ECDHE-RSA-AES128-GCM-SHA256
  - TLS 1.3 uses shortened suites
    TLS_AES_256_GCM_SHA384

Screenshot used with permission from Wireshark.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.0.106	172.217.20.132	TCP	66	53476 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460
2	0.016952	172.217.20.132	192.168.0.106	TCP	66	443 → 53476 [SYN, ACK] Seq=0 Ack=1 Win=60720 Len=
3	0.017028	192.168.0.106	172.217.20.132	TCP	54	53476 → 443 [ACK] Seq=1 Ack=1 Win=131072 Len=0
4	0.018272	192.168.0.106	172.217.20.132	TLSv1.3	688	Client Hello
5	0.036762	172.217.20.132	192.168.0.106	TCP	60	443 → 53476 [ACK] Seq=1 Ack=635 Win=62208 Len=0
6	0.036763	172.217.20.132	192.168.0.106	TLSv1.3	266	Server Hello, Change Cipher Spec, Application Dat
7	0.037274	192.168.0.106	172.217.20.132	TLSv1.3	118	Change Cipher Spec, Application Data
8	0.038669	192.168.0.106	172.217.20.132	TLSv1.3	224	Application Data

```
> Frame 6: 266 bytes on wire (2128 bits), 266 bytes captured (2128 bits) on interface \Device\NPF_{DC478856-D898-4
> Ethernet II, Src: Tp-LinkT_cf:ea:cb (60:e3:27:cf:ea:cb), Dst: Tp-LinkT_15:af:e4 (c4:e9:84:15:af:e4)
> Internet Protocol Version 4, Src: 172.217.20.132, Dst: 192.168.0.106
> Transmission Control Protocol, Src Port: 443, Dst Port: 53476, Seq: 1, Ack: 635, Len: 212
v Transport Layer Security
  v TLSv1.3 Record Layer: Handshake Protocol: Server Hello
      Content Type: Handshake (22)
      Version: TLS 1.2 (0x0303)
      Length: 128
    v Handshake Protocol: Server Hello
        Handshake Type: Server Hello (2)
        Length: 124
        Version: TLS 1.2 (0x0303)
        Random: dba516a7b5f5b3d4f95453c6bbdfe85d73a1db4632640372…
        Session ID Length: 32
        Session ID: 011fa8811607e422d8a3d92ecdd135e6da77498d8b64f75d…
        Cipher Suite: TLS_AES_128_GCM_SHA256 (0x1301)
        Compression Method: null (0)
        Extensions Length: 52
      > Extension: pre_shared_key (len=2)
      > Extension: key_share (len=36)
      v Extension: supported_versions (len=2)
          Type: supported_versions (43)
          Length: 2
          Supported Version: TLS 1.3 (0x0304)
```

API Considerations

```
POST /api/users HTTP/1.1
Content-Type: application/json
{
 "user": {
   "name": "James",
   "email": "jpengelly@comptia.org"
 }
}
```

- Application programming interface (API)
  - Makes web application or service accessible to automation by scripting
  - Passing parameters
- API keys
  - Static keys
  - Authentication and authorization via SAML/OAuth

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Subscription Services

- News and information services
  - Market and financial intelligence and information
  - Security threat intelligence and information
  - Reference and training materials
  - Software applications and cloud services
- Provide secure access
- News feed security
  - Really Simple Syndication (RSS)
  - Atom
  - XML injection and exploits

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

File Transfer Services

- SSH FTP (SFTP)
  - Run FTP over SSH on port 22
- FTP over SSL (FTPS)
  - Explicit TLS (FTPES)—use the AUTH TLS command to upgrade an unsecure connection established over port 21 to a secure one
  - Implicit TLS (FTPS)—negotiate an SSL/TLS tunnel before the exchange of any FTP commands (port 990 for the control connection)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Email Services

- Simple Mail Transfer Protocol (SMTP)
  - Route mail between servers
  - Security mechanisms
    - STARTTLS—explicit TLS
    - SMTPS—implicit TLS
    - Common port configurations
- Mailbox access protocols
  - Post Office Protocol (POP3)
  - Internet Message Access Protocol (IMAP)
    - Better mailbox management features than POP3
  - Secure ports
    - POP3S TCP port 995
    - IMAPS TCP port 993

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

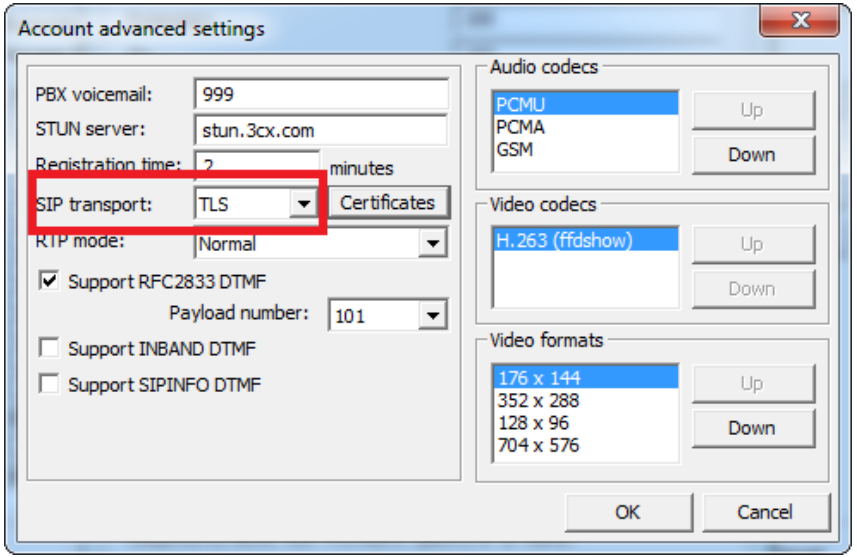
Secure/Multipurpose Internet Mail Extensions

- End-to-end encryption for message contents
- Authentication and confidentiality using PKI certificates
- Correspondents must exchange and trust certificates

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Voice and Video Protocol Security

- Voice over IP (VoIP), web conferencing, and video teleconferencing (VTC)
  - Session control
  - Data transport
  - Quality of service (QoS)
- Session Initiation Protocol (SIP)
  - SIP addresses
  - Integration with external networks via gateways and private branch exchanges (PBX)
  - Secure port 5061 to authenticate callers and encrypt connection setup
- Secure Real-time Transport Protocol (SRTP)
  - Call data confidentiality

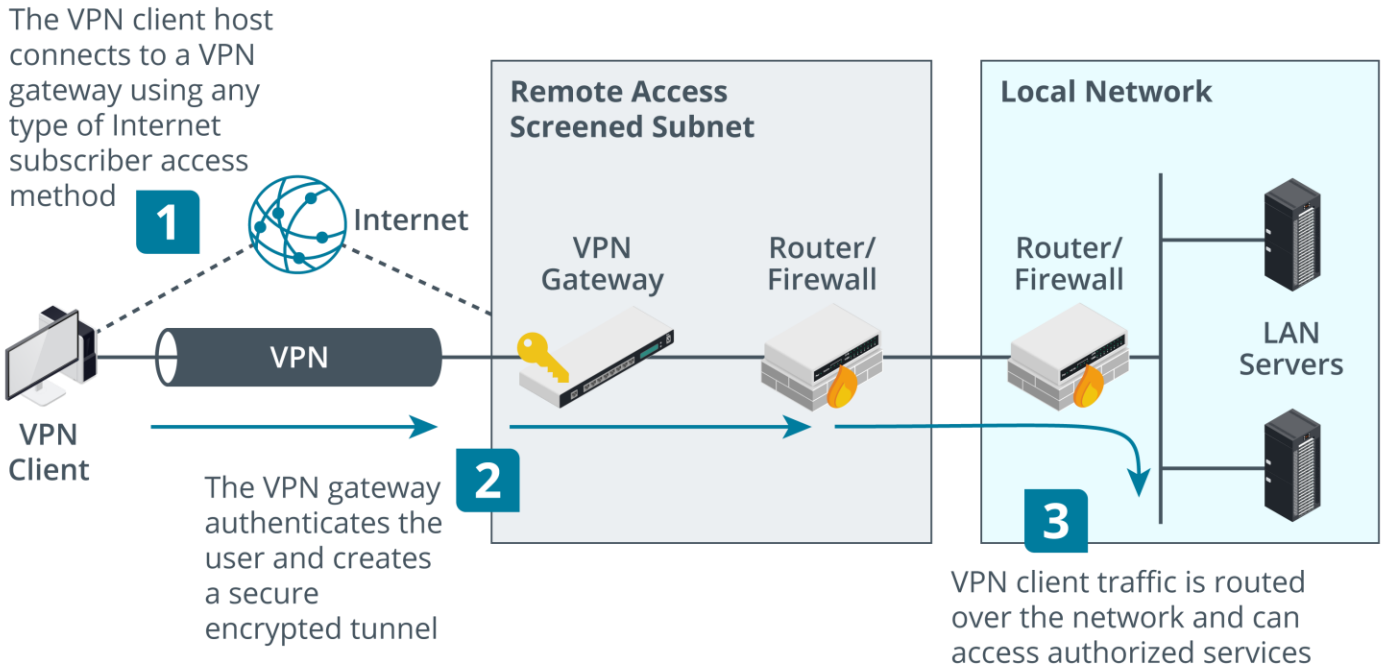


Screenshot used with permission from 3CX.

Topic 11C

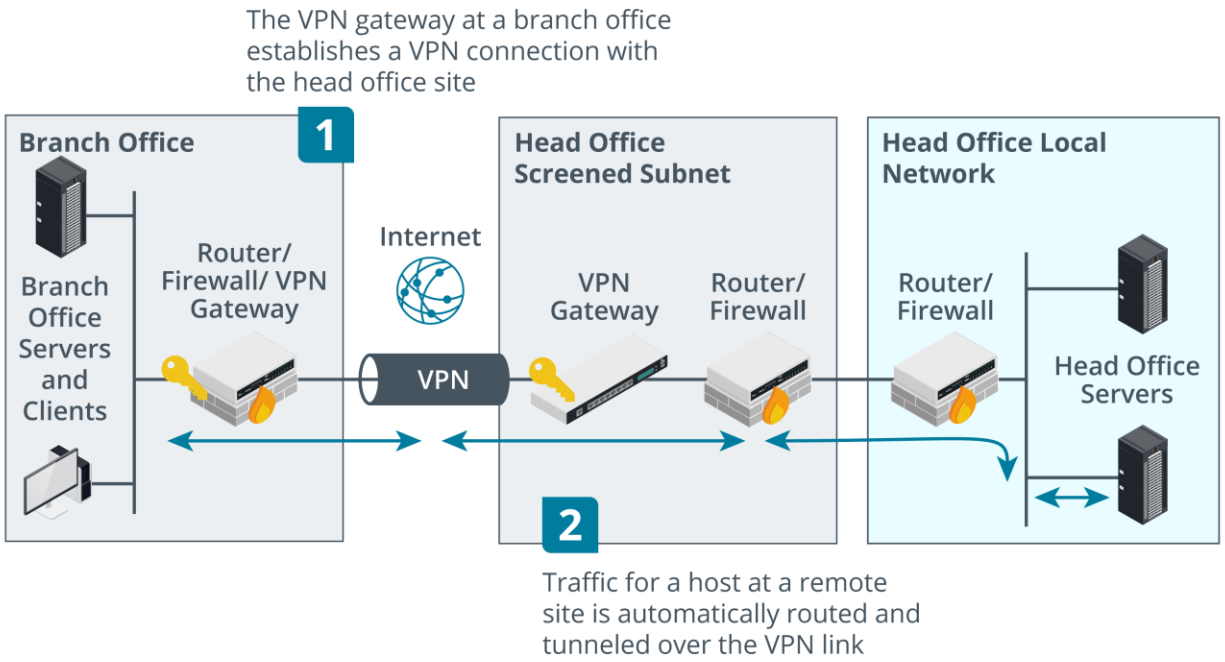
Implement Secure Remote Access Protocols

Remote Access Architecture (1)



Images © 123RF.com.

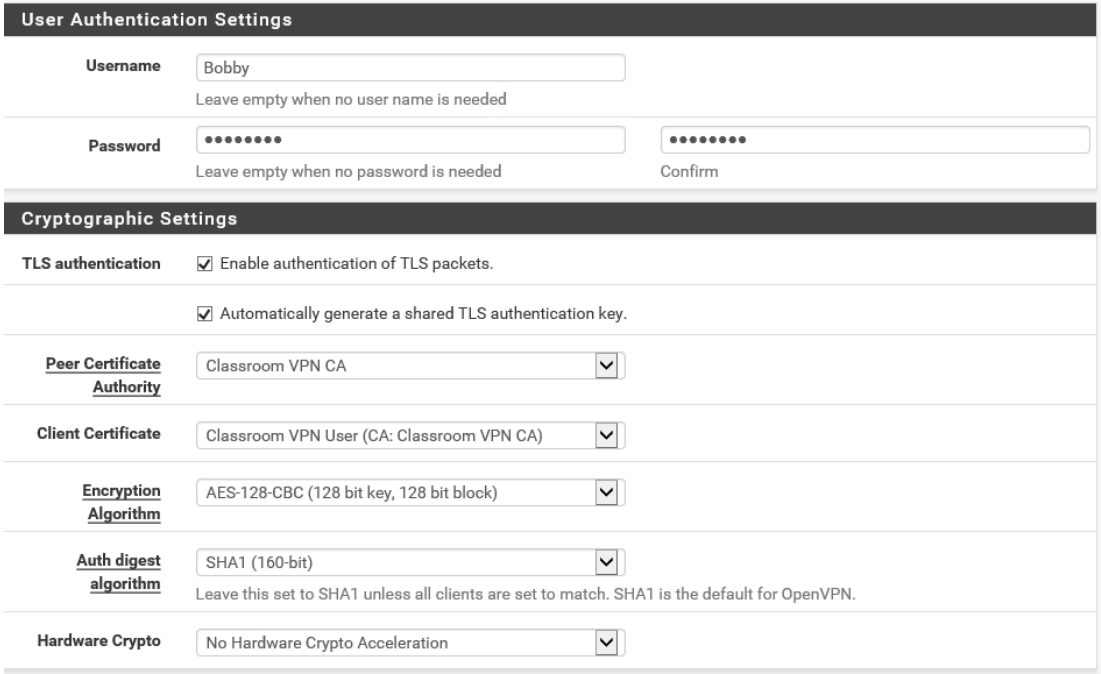
Remote Access Architecture (2)



Images © 123RF.com.

Transport Layer Security VPN

- Use TLS to negotiate a secure connection, authenticated by PKI certificates
- Tunnel network traffic over TLS
- Can use TCP or UDP
- OpenVPN
  - TAP/bridged mode
  - TUN/routed mode
- Secure Sockets Tunneling Protocol (SSTP)
  - Secure tunnel for Point-to-Point Protocol encapsulated local network traffic



Screenshot used with permission from Rubicon Communications, LLC.

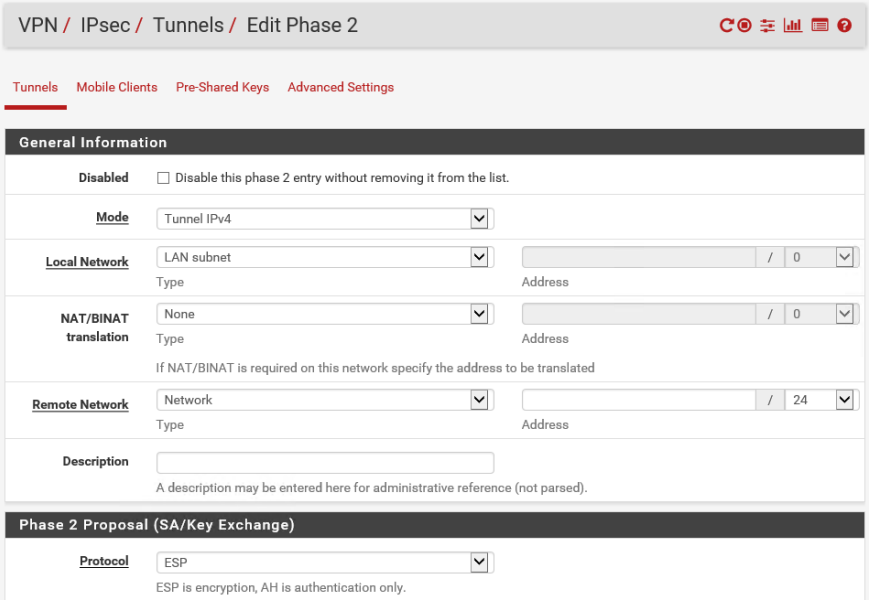
Internet Protocol Security (IPSec)

- Network layer security—application-independent
- Provides confidentiality and/or integrity
- Endpoints must be configured with an IPSec policy and at least one matching security method

- Authentication Header (AH)
  - Signs packet but does not encrypt payload
  - Provides authentication/integrity only
- Encapsulation Security Payload (ESP)
  - Provides confidentiality and/or authentication/integrity

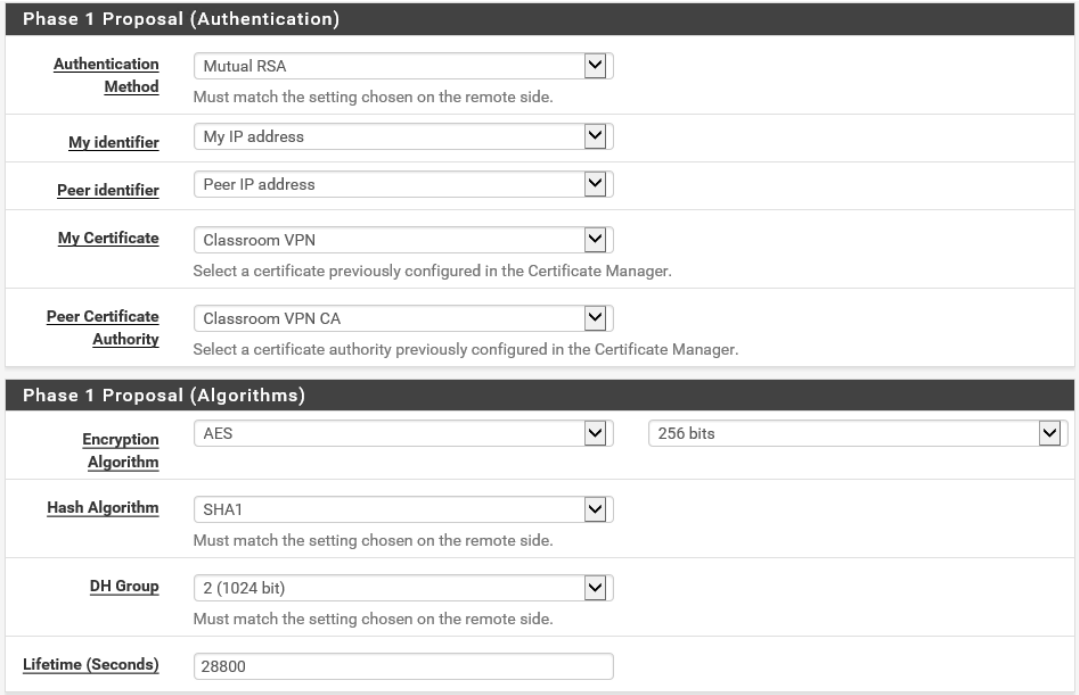
IPSec Transport and Tunnel Modes

- Transport mode for host-to-host connections on a private network
- Tunnel mode between gateways across an unsecure network



Screenshot used with permission from Rubicon Communications, LLC.

Internet Key Exchange



Screenshot used with permission from Rubicon Communications, LLC.

- Internet Key Exchange (IKE)
- Security Association (SA)
- Endpoints must communicate a shared secret and confirm identity
- Phase I provides authentication
  - PKI/certificates
  - Pre-shared key
- Phase II establishes cipher suites and key sizes and use of AH or ESP

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Layer 2 Tunneling Protocol and IKE v2

- Layer 2 Tunneling Protocol/IPSec VPN
  - Use IPSec for secure tunneling of Point-to-Point Protocol (PPP) frames
  - Allows user authentication via EAP or CHAP
- IKE v2
  - Makes IPSec a standalone remote access VPN protocol
  - Support for EAP user authentication methods
  - Reduces number of setup messages
  - Support multihoming on client device (switching between Wi-Fi and cellular data)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

VPN Client Configuration

- Native VPN client or third-party software install
- Configuration
  - VPN gateway address
  - Security type and user credentials
  - Client certificate install
- Always-on VPN
  - Configure VPN to start automatically when trusted network link is detected
- Split tunnel
  - The client accesses the Internet directly using its "native" IP configuration and DNS servers
- Full tunnel
  - Internet access is mediated by the corporate network

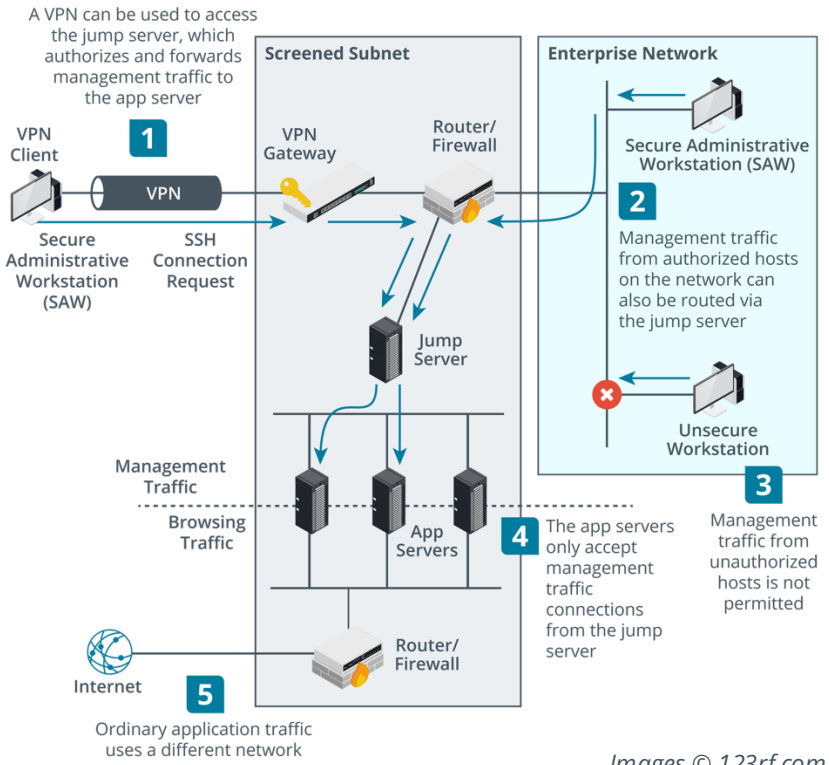
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Remote Desktop

- GUI-based remote terminal software
- Remote Desktop Protocol (RDP)
  - Connect to physical machines
  - RDP gateway to virtual desktops and apps
- HTML5/clientless
  - Access desktops and web applications from Internet via gateway to internal network
  - Browser support for canvas element plus WebSockets

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Out-of-band Management and Jump Servers

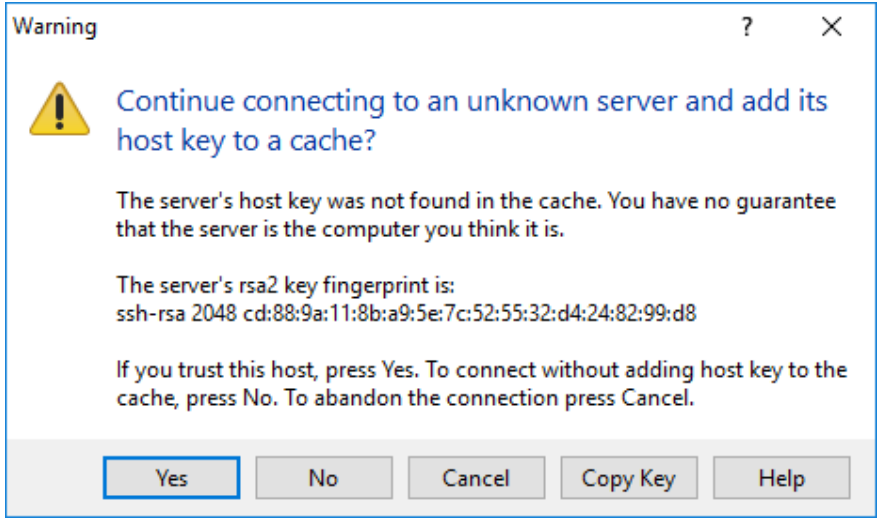


Images © 123rf.com.

- Secure admin workstations (SAWs)
- Out-of-band (OOB) management
  - Serial/modem/console port
  - Virtual terminal
  - Separate cabling or VLAN isolation
- Jump servers
  - Single host accepts SSH or RDP connections from SAWs
  - Forwards connections to app servers
  - App servers only accept connections from jump server

Secure Shell (SSH)

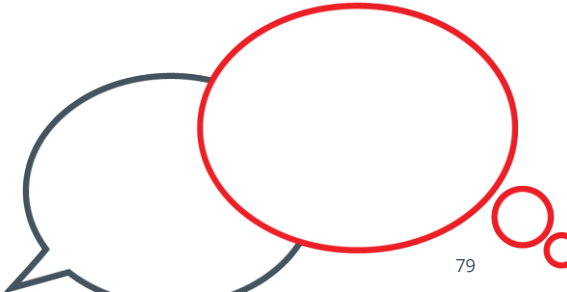
- Remote administration with public key cryptography security
- Host key identifies server
- Client authentication
  - Username/password
  - Public key authentication
  - Kerberos
- Key management
- SSH commands



Screenshot used with permission from PuTTY.

Lesson 11

Summary



Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.